

Fase 1 — Diseño inicial del asistente para MIDTECH S.A.

TFC

Joaquín Nieto Olivares
EX-1222

#INCLUDE 13

ÍNDICE

1. Problema y usuario.....1.

2. Tecnologías elegidas.....1.

3. Flujo de las cuatro capacidades.....2.

4. Diagrama visual del sistema.....2 , 3.

5. Criterio de trazabilidad.....3.

1. Problema y usuario

MIDTECH S.A. es una empresa ficticia del sector salud, biotecnología e industria farmacéutica, con sede principal en Zaragoza y presencia en Madrid y Barcelona. Su actividad con hospitales, laboratorios clínicos y compañías pharma/biotech la sitúa en un entorno especialmente exigente en seguridad de la información, protección de datos y cumplimiento normativo.

El problema principal es que revisar una política de seguridad y compararla con varias normativas puede resultar complejo si se hace de forma manual. Este análisis exige leer documentos extensos, localizar controles relevantes, identificar carencias, responder preguntas de auditoría y formular medidas correctivas concretas.

Para resolver esta necesidad, se propone diseñar un asistente conversacional de ciberseguridad y compliance con IA. Su función será ayudar a analizar la política de seguridad de MIDTECH, detectar posibles incumplimientos, responder preguntas de auditoría y generar propuestas de mejora priorizadas, tomando como referencia GDPR, ISO 27001 y ENS.

El usuario principal será interno: responsable de seguridad, responsable de compliance, auditor interno, equipo IT o dirección técnica. El asistente no sustituye a estos perfiles, sino que actúa como herramienta de apoyo para ordenar información, localizar evidencias y facilitar la toma de decisiones.

2. Tecnologías elegidas

Para el diseño inicial se propone una arquitectura sencilla y realista. El objetivo no es crear una IA desde cero, sino integrar herramientas existentes para recibir consultas, recuperar información documental y generar respuestas estructuradas.

Componente	Herramienta propuesta	Justificación
Modelo LLM	GPT-4o de OpenAI	Permite comprender texto en español, analizar documentos y generar respuestas estructuradas para auditoría, riesgos y mejoras.
Orquestación	n8n	Permite construir flujos visuales sin programar y coordinar la consulta, la búsqueda documental, el prompt y el modelo LLM.
Gestor documental	Google Drive	Servirá para almacenar la política de MIDTECH y los documentos normativos de referencia.
Base de conocimiento	RAG sobre política MIDTECH, GDPR, ISO 27001 y ENS	Permitirá recuperar fragmentos relevantes de los documentos para evitar respuestas genéricas.
Entrada/salida	Chat, formulario o webhook conectado a n8n	Permitirá al usuario introducir preguntas y recibir respuestas estructuradas.

Aunque podrían valorarse otros gestores documentales como Dropbox, se propone Google Drive porque simplifica la organización inicial de los documentos y encaja mejor con el flujo previsto en n8n.

3. Flujo de las cuatro capacidades del asistente

El asistente funcionará mediante cuatro capacidades principales. En todos los casos, el usuario introduce una consulta, el sistema identifica la capacidad que debe activarse, recupera fragmentos relevantes de la política de MIDTECH y/o de la normativa, y el modelo LLM genera una respuesta estructurada.

Capacidad	Entrada del usuario	Proceso previsto	Salida esperada
1. Análisis de políticas	El usuario solicita analizar la política de seguridad de MIDTECH.	El sistema recupera la política, localiza fragmentos relevantes y los envía al modelo con un prompt de análisis.	Informe con áreas cubiertas, nivel de cobertura y áreas ausentes.
2. Detección de riesgos e incumplimientos	El usuario pide comparar la política con GDPR, ISO 27001 o ENS.	El sistema contrasta la política con los requisitos normativos indexados.	Gap analysis con área normativa, carencia, criticidad y referencia normativa.
3. Preguntas de auditoría	El usuario formula una pregunta concreta, por ejemplo: “¿Cumplimos con el artículo 32 del GDPR?”	El sistema busca evidencias en la política y en la normativa aplicable.	Respuesta conversacional indicando qué dice la política, qué exige la norma y una conclusión.
4. Propuestas de mejora	El usuario solicita recomendaciones o acciones de mejora.	El sistema parte de las carencias detectadas y genera propuestas priorizadas.	Lista de mejoras con normativa que la justifica, prioridad y esfuerzo estimado.

Cada capacidad utilizará un prompt de sistema específico para adaptar la respuesta a la tarea: analizar, comparar, responder o proponer mejoras.

4. Flujo general del sistema y diagrama visual

El diagrama representa la arquitectura lógica prevista para el asistente. El usuario interno de MIDTECH introduce una consulta mediante una interfaz de entrada. n8n recibe la solicitud, gestiona el flujo y clasifica qué capacidad debe activarse.

A partir de esa clasificación, el sistema aplica el prompt correspondiente, consulta la base documental formada por la política de MIDTECH y las normativas GDPR, ISO 27001 y ENS, recupera fragmentos relevantes mediante RAG y envía ese contexto al modelo GPT-4o de OpenAI.

El modelo genera una salida estructurada según la capacidad activada: informe de análisis, gap analysis, respuesta de auditoría o plan de mejoras. Finalmente, el asistente responde al usuario y registra la evidencia de la prueba para mantener la trazabilidad del sistema.

ASISTENTE DE CIBERSEGURIDAD Y COMPLIANCE

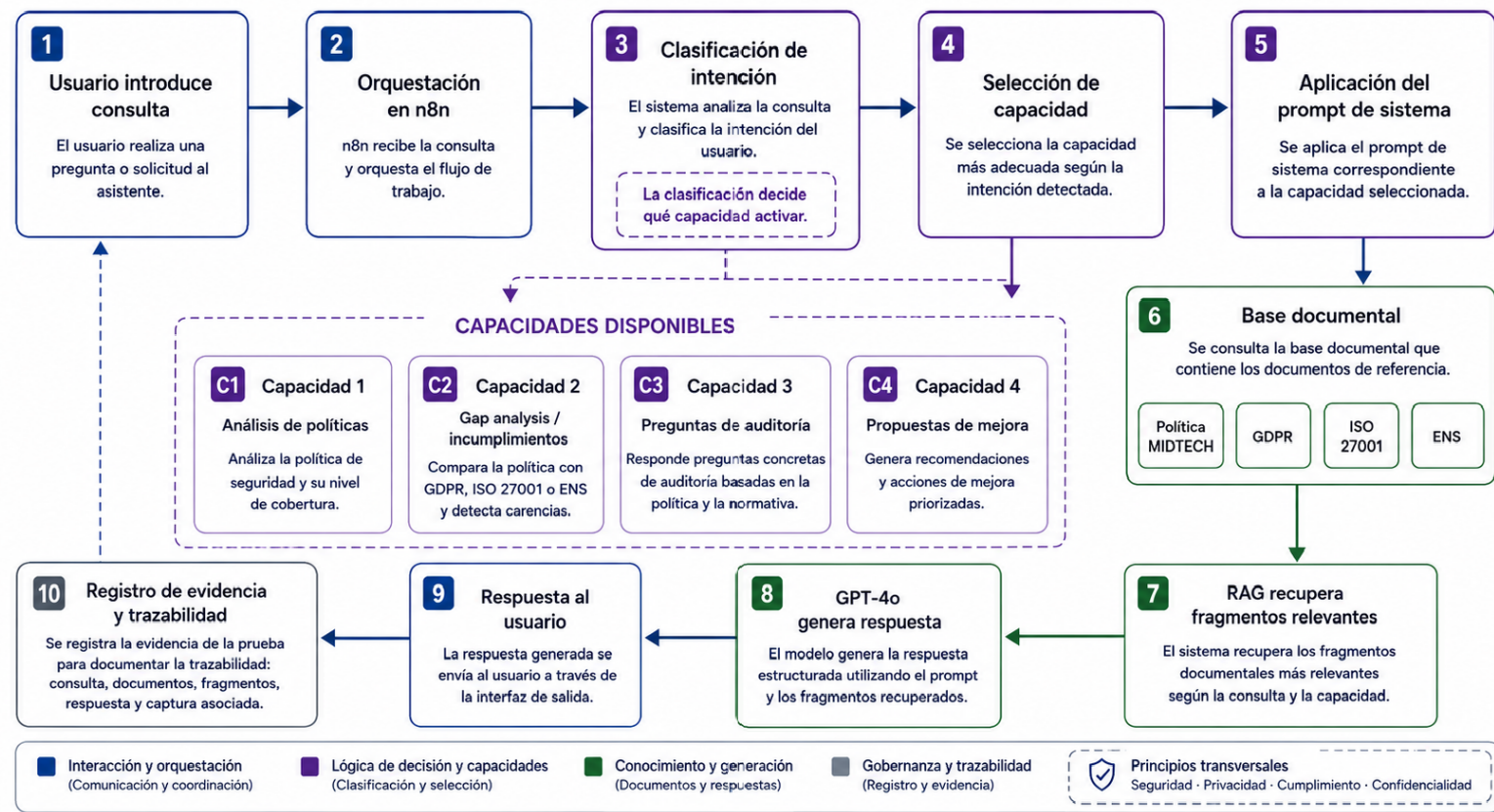


Figura 1. Diagrama del flujo completo del asistente.
El flujo muestra la entrada del usuario, la orquestación en n8n, la consulta a la base documental mediante RAG, la generación de respuesta con GPT-4o y el registro de evidencia para mantener la trazabilidad.

5. Criterio de trazabilidad

Como criterio de diseño, cada prueba del asistente deberá poder relacionarse con:

Pregunta realizada → documento consultado → fragmento recuperado → respuesta generada → captura asociada

Esta trazabilidad permitirá comprobar en las siguientes fases que el asistente no genera respuestas genéricas, sino que utiliza realmente la política de MIDTECH y las normativas cargadas como base documental.

